

1. Ambiente operativo e obiettivi

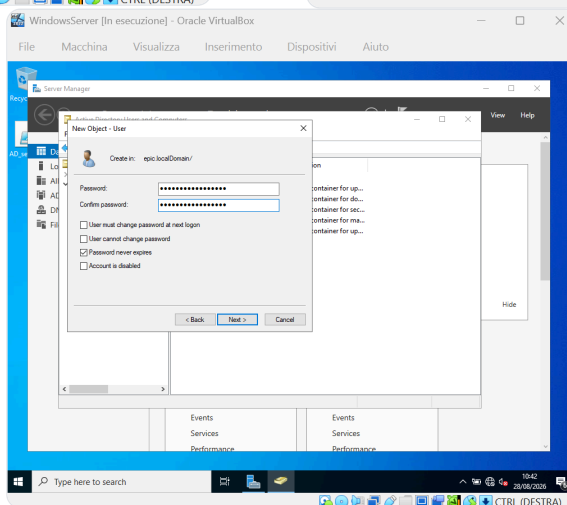
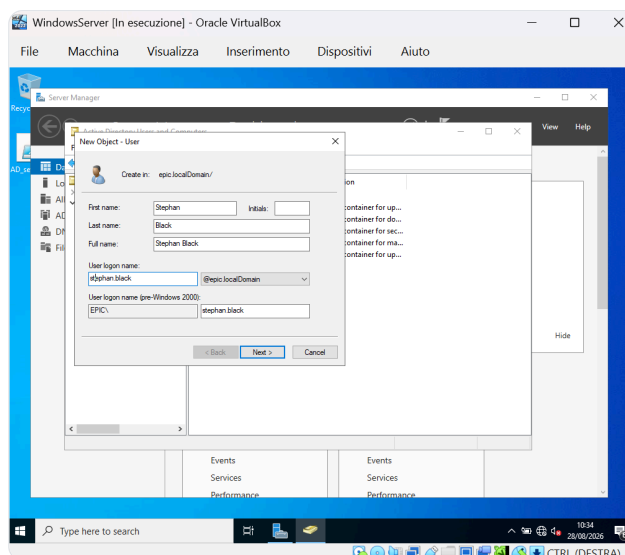
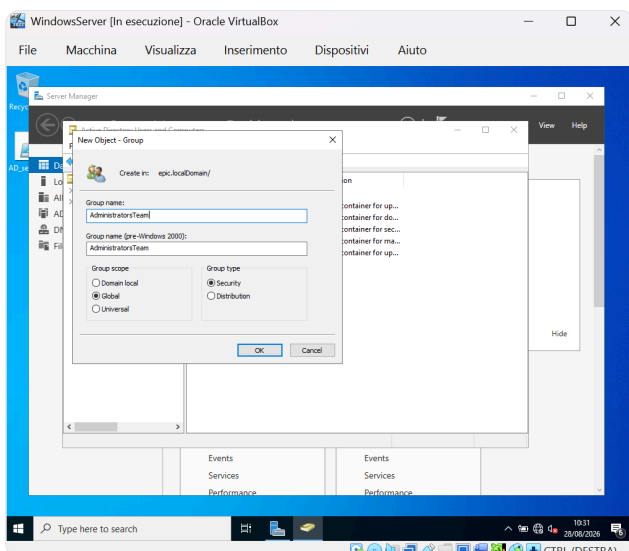
L'attività descritta nel presente report è stata eseguita all'interno di un ambiente di virtualizzazione gestito tramite l'hypervisor *Oracle VM VirtualBox*. In tale infrastruttura virtuale è stata creata e configurata un'istanza del sistema operativo Windows Server 2022 con il ruolo di Controller di Dominio (*Active Directory Domain Services*).

L'obiettivo principale del presente report è la dimostrazione dei processi di gestione centralizzata degli utenti e dei gruppi di sicurezza all'interno del dominio. Nello specifico, le attività mirano a strutturare una corretta gerarchia organizzativa, creare e associare gli account utente, applicare il principio del minimo privilegio tramite l'assegnazione mirata delle autorizzazioni NTFS e dei criteri di gruppo (GPO), e verificare la corretta applicazione delle restrizioni di sicurezza.

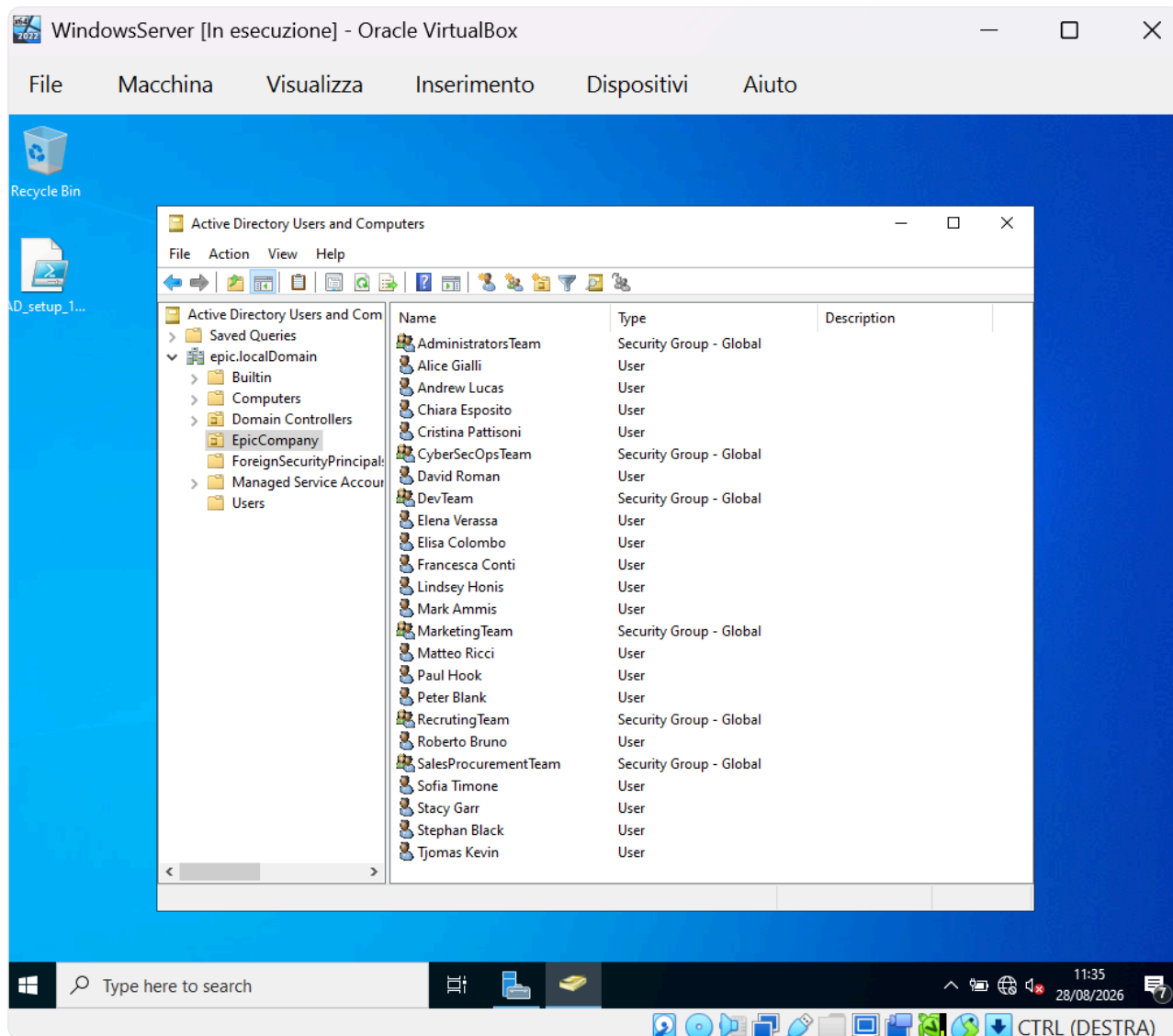
2. Creazione e configurazione dei gruppi

La procedura di popolamento dell'infrastruttura Active Directory è stata eseguita tramite la console Utenti e computer di Active Directory (*dsa.msc*), seguendo il seguente flusso di creazione di gruppi di sicurezza e account utente:

- Nella creazione del gruppo di sicurezza, all'interno del dominio `epic.localDomain`, è stato creato il gruppo di sicurezza `AdministratorsTeam`. In questa operazione sono stati impostati i parametri:
 - Group Scope* a `Global` (Consente l'assegnazione dei membri appartenenti allo stesso dominio per accedere a risorse in qualsiasi dominio della foresta).
 - Group Type* a `Security` (Abilita l'assegnazione diretta di autorizzazioni su file, cartelle e criteri di gruppo).
- Nella Configurazione dell'account utente, `stephan.black` in esempio di configurazione tipica, è stato configurato il logon name (UPN), in questo caso `stephan.black@epic.localDomain`, e lo User logon name (pre-Windows 2006), in questo caso `EPIC\stephan.black`.
- Nella impostazione dei requisiti di autenticazione, per ciascun account è stata assegnata una password complessa generata secondo la nomenclatura `<prime 3 lettere nome><prime 3 lettere cognome>.Epicpass!` (`stebla.Epicpass!` in esempio per l'utente). Inoltre, in questa attività, e nella fase di provisioning, è stata selezionata l'opzione "Password never expires" per gli account di servizio/amministrazione di test, deselegnando "User must change password at next logon".



Schermate del processo di configurazione del gruppo AD gruppo AD `AdministratorsTeam`, e di un utente previsto per questo gruppo. La password impostata segue la seguente nomenclatura: `<prime 3 lettere nome><prime 3 lettere cognome>.Epicpass!`



Schermata della vista della *Organizational Unit* (OU) *EpicCompany* al termine del processo di configurazione dei gruppi AD e dei relativi utenti nel pannello *Active Directory Users and Computers*

3. Matrice di appartenenza degli utenti-gruppi AD

Di seguito viene riportata la struttura dei gruppi di sicurezza creati in Active Directory con l'elenco dei rispettivi membri associati e i relativi nomi utente (*username*)

Gruppo	Membri (Nome e Cognome)
AdministratorsTeam	- Mark Ammis [mark.ammis] - Elena Verassa [elena.verrassa] - Stephan Black [stepan.black]
MarketingTeam	- Chiara Esposito [chiara.esposito] - Elisa Colombo [elisa.colombo] - David Roman [david.roman] - Peter Blank [peter.blank]
DevTeam	- Paul Hook [paul.hook] - Tjomas Kevin [tjomas.kevin] - Lindsey Honis [lindsey.honis] - Cristina Pattisoni [cristina.pattisoni] - Stacy Garr [stacy.garr]
CyberSecOpsTeam	- Tjomas Kevin [tjomas.kevin] - Andrew Lucas [andrew.lucas] - Paul Hook [paul.hook]
RecrutingTeam	- Alice Gialli [alice.galli] - Sofia Timone [sofia.timone] - Roberto Bruno [roberto.bruno]
SalesProcurementTeam	- Matteo Ricci [matteo.ricci] - Francesca Conti [francesca.conti]

4. Struttura dell'albero delle cartelle

Per garantire una gestione organizzata delle risorse aziendali e l'applicazione efficiente delle autorizzazioni NTFS/SMB, è stata definita una struttura gerarchica di cartelle sul volume di dati del server (*C:\EpicOrgData*).

Ogni reparto/gruppo di lavoro dispone di una cartella condivisa dedicata, configurata secondo il principio del minimo privilegio: gli utenti hanno accesso esclusivamente alle risorse pertinenti al proprio ruolo operativo.

4.1. Albero gerarchico e mappa ACL

Per garantire una gestione organizzata delle risorse aziendali e l'applicazione efficiente delle autorizzazioni NTFS/SMB, è stata definita una struttura gerarchica di cartelle sul volume di dati del server.

A partire dalla cartella *radice* dell'albero gerarchico dei percorsi delle risorse del gruppo (OU) `EpicCompany`, assegnata al percorso `C:\EpicOrgData`, si è definito il seguente albero gerarchico:

- `Administrators`, per il gruppo `AdministratorsTeam`
- `Marketing`, per il gruppo `MarketingTeam`
- `Development`, per il gruppo `DevTeam`
- `CyberSecOps`, per il gruppo `CyberSecOpsTeam`
- `Recruiting`, per il gruppo `RecruitingTeam`
- `SalesProcurement`, per il gruppo `SalesProcurementTeam`

Per la gestione degli accessi, è stata definita, tramite il comando `Set-Acl` nel software "di linea di comando" PowerShell la seguente mappa di access control list :

Nome della cartella	ACL del gruppo AD <code>AdministratorsTeam</code>	ACL del gruppo AD <code>MarketingTeam</code>	ACL del gruppo AD <code>DevTeam</code>	ACL del gruppo AD <code>CyberSecOpsTeam</code>	ACL del gruppo AD <code>RecruitingTeam</code>	ACL del gruppo AD <code>SalesProcurementTeam</code>
<code>Administrators</code>	Controllo Completo (<i>Full Control</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)
<code>Marketing</code>	Controllo Completo (<i>Full Control</i>)	Modifica Read/Write/Delete	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)
<code>Development</code>	Controllo Completo (<i>Full Control</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Modifica Read/Write/Delete	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)
<code>CyberSecOps</code>	Controllo Completo (<i>Full Control</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Modifica Read/Write/Delete	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)
<code>Recruiting</code>	Controllo Completo (<i>Full Control</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Modifica Read/Write/Delete	Negazione esplicita (<i>Explicit Deny</i>)
<code>SalesProcurement</code>	Controllo Completo (<i>Full Control</i>)	Consenso alla sola lettura (<i>Read,Read & execute,List folder contents</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Negazione esplicita (<i>Explicit Deny</i>)	Modifica Read/Write/Delete

Relativamente ai percorsi del protocollo *Server Message Block* (SMB), sono definiti i seguenti percorsi remoti:

- `\\EPIC\Administrators$`, definito per il gruppo `Administrators` in condivisione nascosta, punta al percorso `C:\EpicCompany\Administrators` ;
- `\\EPIC\Marketing`, definito per il gruppo `Marketing`, punta al percorso `C:\EpicCompany\Marketing` ;
- `\\EPIC\Development`, definito per il gruppo `Development`, punta al percorso `C:\EpicCompany\Development` ;
- `\\EPIC\CyberSecOps`, definito per il gruppo `CyberSecOps`, punta al percorso `C:\EpicCompany\CyberSecOps` ;
- `\\EPIC\Recruiting`, definito per il gruppo `Recruiting`, punta al percorso `C:\EpicCompany\Recruiting` ;
- `\\EPIC\SalesProcurement`, definito per il gruppo `SalesProcurement`, punta al percorso `C:\EpicCompany\SalesProcurement` .